

The vendor's AI was approved to predict failures. Its access told a different story.

Ramya Amballa, AI for U&I

Illustrative simulated case. Sandline Gas Processing Company (SGPC) and Meridian Asset Analytics are fictional. No real operator, vendor or facility is represented. No incident occurred. No production write, control action, Phase 2 activation or production update was performed. The evidence is illustrative. The reasoning and the work products are mine. This is not a client engagement.

A vendor removes a write-capable credential, provisioned for a future phase, from its AI gateway. That should settle it. It does not. The network path behind it stays open, although nobody has shown the AI could write through it. This case shows how to reconcile what a contract permits, what the technology can do, what the evidence shows and who actually approved it, before an industrial AI deployment goes ahead.

Where the case stands **SIMULATED FINDING**

- 11 vendor capabilities reviewed. One is authorised and verified.
- Five exposures are not yet contained.
- Six findings are open. None is closed.
- 19 formal verification tests not yet performed. The findings rest on a simulated review and first retest.
- Phase 1 deployment approval has not been granted.

The situation **SIMULATED FINDING**

A gas processor is deploying a vendor's predictive-maintenance AI on a critical compressor train. Phase 1 is advisory only. The AI predicts failures. A reliability engineer decides what to do and raises any work request. The AI cannot.

During the pre-deployment review, a write-capable integration credential turned up on the vendor's edge gateway. It had been provisioned for a future phase. The vendor removed it. The vendor has also proposed Phase 2: autonomous optimisation.

The question put to me was simple. Can Phase 1 go ahead?

The question that actually mattered

Not whether the AI predicts well. Whether four things line up for every vendor capability: what the contract permits, what the technology can do, what the evidence shows, and who in the operator approved it.

So I built a register to reconcile those four positions, interface by interface, identity by identity, data flow by data flow. It classifies each capability. It does not score it. A capability is either authorised and verified, authorised but unverified, beyond its authority, undefined because the contract is silent, or short of evidence.

What the review found **SIMULATED FINDING**

The credential went. The path stayed. The firewall rule that let the gateway reach the OPC server was still in place, and its removal had not gone through OT change control. Could the AI write through it? **NOT ESTABLISHED** Nobody had shown that it could, and nobody had shown that it could not. So it is recorded as unresolved reachability, not as write access.

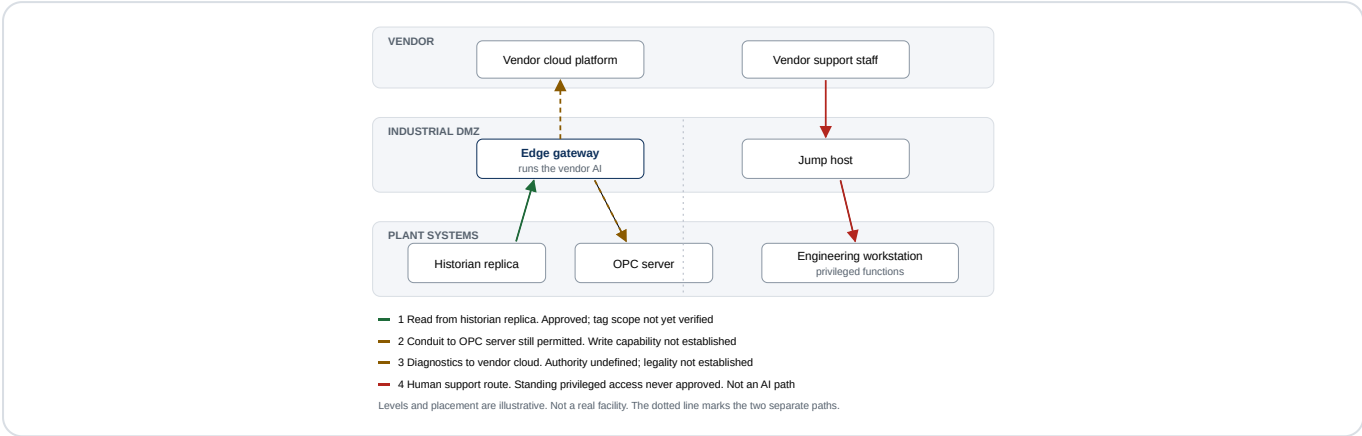
The first retest did not pass, for a different reason. A vendor support route, authorised under the support agreement, gave six named support engineers standing access to privileged engineering workstation functions. No time limit, no per-session approval, and never approved by the operator. That is human vendor access. **NOT ESTABLISHED** Nothing in the evidence shows the AI can use that route, and I did not assume it either way. A separate test is specified to check.

Diagnostics were leaving for the vendor's cloud with no defined authority. The contract said nothing about content, destination, hosting, retention or use, and there was no classification decision. That is a governance gap. **NOT ESTABLISHED** Whether the transfer meets or breaches any law is not established, and it is not mine to decide.

The Phase 2 module was already on the gateway. Or so the vendor says. Installed and disabled, by its own statement.

NOT ESTABLISHED Neither point has been independently verified.

Two more questions stayed open. Whether software and model updates install automatically is unknown. And the contract had no subcontractor terms, though **NOT ESTABLISHED** nobody has shown a subcontractor holds access.



Simplified view of the fictional architecture. The AI's data path (left) and the human vendor support path (right) are kept separate in the analysis. Nothing in the case shows the AI using the support route.

The decision **PROPOSED**

Phase 1 deployment approval is not granted.

A temporary, restricted advisory exception may be permitted for the one verified function, the engineer-reviewed recommendations, and the authorised capabilities it depends on. Only after the containment restrictions are independently verified and the operator's risk owner formally accepts the restricted condition. Anything that cannot be contained is suspended now, not at a later date.

Phase 2 is not considered for approval. It inherits nothing from Phase 1. It goes through the operator's Management of Change process.

Phase 1 can be reconsidered when

1. The conduit is closed under change control, and that is independently verified.
2. Support access is scoped, time-limited and reviewed, and the AI and human paths are shown to be separate.
3. Diagnostics are limited to agreed fields, with a documented classification and processing position.
4. The Phase 2 module is verified disabled, with only the operator able to enable it.
5. The update mode is confirmed and gated by change control.
6. Subcontractors are named, with contract terms flowed down.
7. A contract addendum is executed after legal review.
8. Changes that require re-reconciliation are wired to change and vendor notifications.
9. Every remaining open register row is verified or formally accepted by its owner.

A clean register without this evidence does not meet the conditions.

What I did not decide **OPEN DECISION**

Whether Phase 2 needs hazard review or HAZOP revalidation is for the process-safety engineers. Data classification and transfer requirements are for legal and data governance. Whether any active network test is acceptable is for OT security and operations. The package names where each decision is needed. It does not make them.

Free template: the pre-meeting checklist and blank Vendor AI Authority Register are at aiforui.org/downloads/case-02-vendor-ai-authority-register-template.xlsx. Full case: aiforui.org/cases/case-02.

Reference. The package cites controls from the NCA Operational Technology Cybersecurity Controls (OTCC-1:2022). Cloud, data and classification requirements are marked for legal verification and are not asserted here. Applicability is professional opinion on simulated facts.